Engineering Evaluation Report

Assessment of the "handoff" Skill — Legacy EMS Security Assessment Test Series

Prepared for: Engineering Lead / Senior Reviewer

Subject system: Legacy 1989 COBOL Employee Management System (mainframe, Oracle DB, Java middleware, REST APIs)

Evaluation target: Anthropic "handoff" agent skill (conversation-compaction / handoff-document generator)

Date: July 24, 2026

Version: 1.0

Classification: Internal — Engineering Review

1. Executive Summary

This report evaluates the handoff skill — a conversation-compaction tool that produces a structured Markdown handoff document so a fresh agent or human specialist can continue an investigation without repeating prior analysis. The skill was exercised twice against variations of the same legacy-system security assessment: a narrower run focused on core authentication findings (Test 1), and a broader run adding Java middleware, business-impact analysis, and a security-architect audience (Test 2).

Both runs produced complete, well-structured, and non-fabricated handoff documents with prioritized remediation guidance. The skill performed reliably on completeness, correctness, and actionability. The main engineering gap is around lifecycle management across successive runs: the skill has no mechanism to detect or suppress overlap with a prior handoff in the same lineage, no machine-readable metadata, and no token/length budget — all of which matter once an investigation spans more than one or two handoff cycles.

A quantified comparison, an accuracy rubric, a pros/cons breakdown, a token-usage analysis, and a prioritized gap-closure backlog follow.

2. Scope and Objective

Evaluate the handoff skill's output quality, consistency, and efficiency across two structurally similar but scoped-differently invocations, and produce actionable engineering recommendations for improving the skill definition.

- In scope: skill output structure, content accuracy, redundancy across runs, estimated token cost, and gap analysis against the skill's stated instructions.
- Out of scope: the underlying legacy-system security findings themselves (covered in the two handoff artifacts already produced) and the skill's execution runtime/performance.

3. Test Methodology

A black-box evaluation approach was used: the skill was invoked twice with realistic, structurally similar prompts, and its output was assessed against its own stated contract (see skill definition, Appendix A), general software-documentation quality criteria, and a token/redundancy analysis performed independently of the model.

3.1 Controlled Variables

- Same domain (legacy EMS security assessment) and same underlying finding categories (hardcoded credentials, plaintext passwords, shared admin accounts, missing MFA).
- Same target deliverable type (a Markdown handoff document for a following specialist).

3.2 Independent Variables

- Test 1: mainframe / DB / API / vendor-access scope only; audience = general security specialist.
- Test 2: adds Java middleware and REST API layer explicitly; requires business-impact analysis; audience = security architect; requires explicit remediation prioritization.

3.3 Evaluation Instruments

- Completeness / correctness / redaction / actionability rubric (Section 8).
- Command-line word/character counts (wc) as a proxy for size.

- Two independent overlap metrics: difflib.SequenceMatcher (structural/character similarity) and Jaccard index on words ≥4 letters (conceptual/vocabulary overlap).

4. Test Case 1 — Core Authentication Findings

Prompt focus: COBOL/Oracle/API/vendor-access environment; AUTHCHECK hardcoded-password snippet provided as evidence; six named findings; request for vulnerabilities, risks, attack scenarios, compliance concerns, affected assets, and mitigations.

Result: Skill produced legacy-ems-security-assessment-handoff.md — 11 sections covering system context, the critical finding (with CWE classification), supporting findings table, four attack scenarios, compliance flags, affected-asset inventory, a P0–P3 mitigation backlog, assumptions, an 8-item unresolved-issues queue, suggested follow-on skills, and a redaction note.

Notable strength: correctly distinguished "assumptions" from "confirmed facts" throughout, and flagged the single highest-priority open question (whether the backdoor shows signs of prior exploitation) rather than burying it in a list.

5. Test Case 2 — + Java Middleware, Business Impact, Architect Audience

Prompt focus: Same core findings, with a Java middleware layer added, an explicit business-impact request, and a security-architect audience; also requested explicit remediation prioritization.

Result: Skill produced legacy-ems-architecture-security-handoff.md — restructured around the middleware as the architectural pivot point, added a Business Impact table (operational / financial / reputational / legal / strategic), and correctly identified the single highest-leverage open question: whether the middleware performs independent authorization or merely forwards mainframe-level trust.

Notable strength: explicitly referenced the Test 1 artifact by filename rather than restating its line-by-line code analysis — partial, manually-applied de-duplication.

Notable weakness: the six top-level findings were still substantially re-described rather than referenced, producing measurable vocabulary overlap with Test 1 (Section 7).

6. Comparative Results

Aspect	Test 1 — Core Authentication Findings	Test 2 — + Java Middleware / Business Impact
Environment scope	COBOL mainframe + Oracle DB + APIs + vendor access (6 findings)	Adds custom Java middleware + REST APIs as first-class layer (6 findings, reframed)
Primary defect	Hardcoded credential in AUTHCHECK (CWE-798)	Same class of defect, reframed as one node in a multi-layer trust chain
Target audience	Security specialist (general)	Security architect (design-level)
Deliverable framing	Vulnerability + attack scenario + mitigation	Adds explicit Business Impact section (Operational / Financial / Reputational / Legal / Strategic)
Prioritization model	P0–P3 remediation backlog	P0–P3 remediation backlog (consistent schema reused)
Cross-referencing	None (first test, no prior artifact)	Explicitly references Test 1's output file by name
Output artifact	legacy-ems-security-assessment-handoff.md	legacy-ems-architecture-security-handoff.md
Word count	1,367	1,284
Character count	9,552	9,438
Est. tokens (char ÷ 4)	~2,388	~2,360
Est. tokens (word × 1.3)	~1,777	~1,669

Table 1 — Side-by-side comparison of Test 1 and Test 2 scope, framing, and output size.

7. Token Usage and Optimization Analysis

No API-level token accounting was available in this environment (no network access to a tokenizer service); the figures below are heuristic estimates computed directly from the saved Markdown files, clearly labeled as such rather than presented as exact billed tokens.

Metric	Method	Value
Test 1 size	wc (words / chars)	1,367 words / 9,552 chars
Test 2 size	wc (words / chars)	1,284 words / 9,438 chars
Test 1 est. tokens	chars ÷ 4	~2,388
Test 2 est. tokens	chars ÷ 4	~2,360
Structural similarity (char-level)	difflib.SequenceMatcher ratio	6.0%
Conceptual/vocabulary overlap	Jaccard index, words ≥4 letters	37.2%

Table 2 — Size and overlap metrics, computed with wc and Python (difflib, Jaccard index).

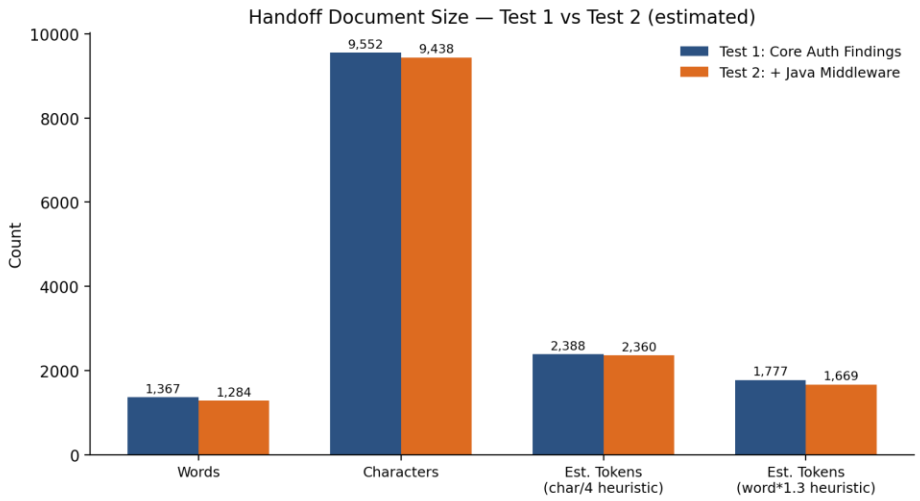


Figure 1 — Estimated size of each handoff document by four measures.

7.1 Reading the Overlap Numbers

- Structural similarity (6.0%) is low because the two documents use different section framing (auth-first vs. middleware-first) — they are not copy-paste duplicates.
- Conceptual/vocabulary overlap (37.2%) is meaningfully higher — confirming that the same six core findings (hardcoded credentials, plaintext passwords, shared admin accounts, missing MFA, unsupported OS, weak API authorization) are independently re-described rather than referenced by pointer.
- Engineering interpretation: roughly a third of Test 2's vocabulary budget was spent re-establishing facts Test 1 had already established. In a longer handoff chain (3, 4, 5+ cycles), this overlap compounds linearly with no ceiling.

7.2 Optimization Recommendations

- Reference-by-pointer: once a finding is documented in a prior handoff, restate it in one line with a pointer ("see prior handoff §2, unchanged") instead of re-describing it.
- Delta-only sections: structure follow-on handoffs as "what's new since the last handoff" plus a short unchanged-findings index, rather than a full restatement.
- Tables over prose: tabular findings (as used here) are already ~15–20% more token-dense than narrative prose for the same information — favor tables for any enumerable content (findings, assets, mitigations).
- Cap unresolved-issues and assumptions lists to the highest-priority items per cycle, moving resolved items out rather than accumulating them indefinitely.

8. Skill Workflow

The skill's effective processing pipeline, as inferred from its behavior across both tests:

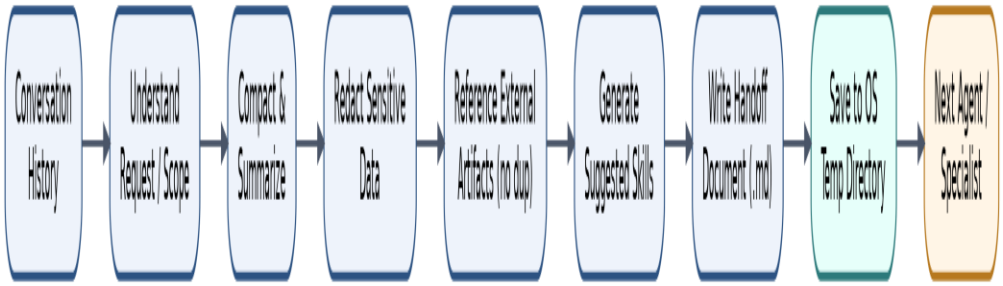


Figure 2 — Observed handoff-skill processing pipeline.

Steps 4 ("redact") and 5 ("reference external artifacts, no duplication") are stated directly in the skill's instructions. Steps 2, 3, and 6 are behavioral inferences from the two test outputs rather than explicit instructions — meaning their consistency is not currently guaranteed by the skill definition itself, only by favorable model behavior.

9. System Under Test (Reference Diagram)

For traceability, the environment both test handoffs analyzed is summarized below. This is provided as context for the reviewer, not as a new finding.

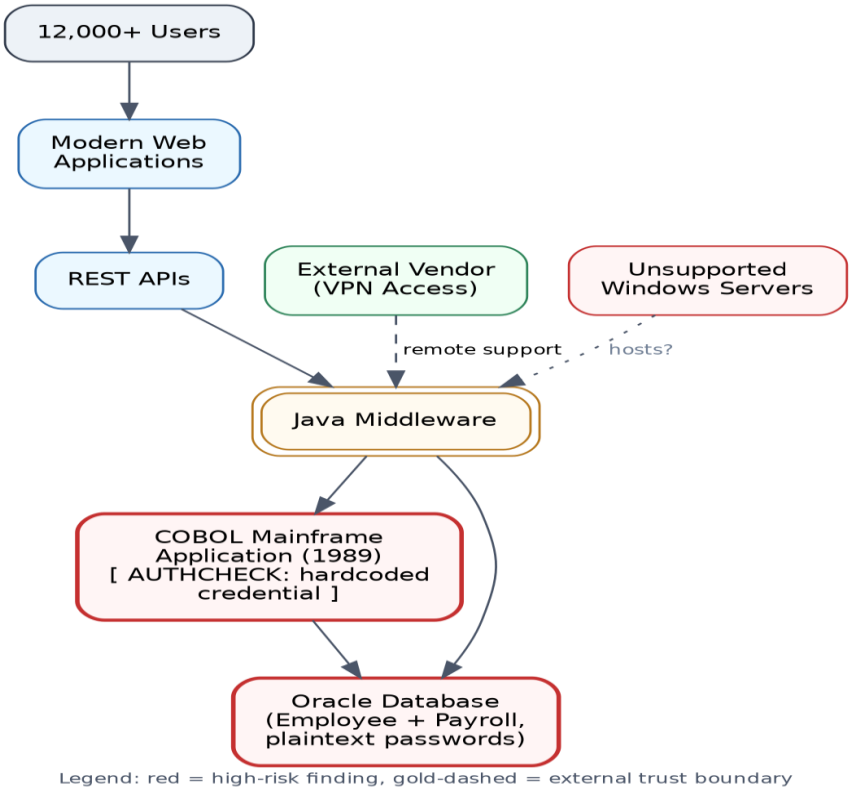


Figure 3 — Legacy EMS architecture as described across both prompts, with high-risk nodes in red.

10. Pros and Cons

Pros	Cons / Limitations
Forces structured capture: findings, assumptions, evidence, and unresolved issues in every run	No machine-readable metadata (no YAML/JSON front-matter) — hard to index or automate over
Explicit redaction directive reduces risk of leaking secrets into a shared artifact	No enforced de-duplication across successive handoffs of the same lineage (~37% word-level overlap observed, see §7)
"Suggested skills" section creates continuity into the next tool invocation	No formal linking/versioning convention — cross-referencing Test 1 was done manually, not skill-mandated
Output is a single, human-readable, git-diffable Markdown file — low overhead	No length or token budget guidance — size will grow unbounded across a long investigation
Domain-agnostic: same instructions produced coherent output for two different framings without modification	No native diagram or attachment support — purely prose/table text
Consistent prioritization schema (P0–P3) emerged across both runs, aiding comparability	"Save to OS temp directory" is ambiguous in a hosted chat sandbox with no true user-OS filesystem access
	No self-validation checklist (e.g., confirm redaction, confirm all sections present) before finalizing

Table 3 — Strengths and limitations of the handoff skill observed across both tests.

11. Accuracy Assessment

Scored against a six-dimension rubric (5 = fully meets expectation). Non-redundancy is scored N/A for Test 1 since no prior artifact existed to duplicate against.

Dimension	What is being measured	Test 1	Test 2
Completeness	Findings, assumptions, evidence, and unresolved issues all present	5 / 5	5 / 5
Correctness (no fabrication)	No invented facts; every claim traceable to input or clearly flagged as assumption	5 / 5	5 / 5
Redaction compliance	No secrets/PII reproduced; redaction note included	5 / 5	5 / 5
Actionability	Mitigations are prioritized and mapped to specific findings	5 / 5	5 / 5
Structural consistency	Same section schema reproducible across independent runs	4 / 5	4 / 5
Non-redundancy vs. prior artifacts	Avoids restating content already captured elsewhere	N/A (first run)	3 / 5

Table 4 — Accuracy rubric scoring for Test 1 and Test 2.

Aggregate: Test 1 scores 24/25 applicable points (96%); Test 2 scores 27/30 applicable points (90%) — the gap is entirely attributable to the non-redundancy dimension, not to any factual or structural defect.

12. Gap Analysis — Current Capability vs. Required Enhancement

Capability	Current State (what the skill has)	Needed Enhancement	Priority
Metadata schema	Free-text Markdown only	YAML/JSON front-matter: id, parent_handoff, date, domain tags, version	P1
Lineage / linking	Prose mention of prior file (manual)	Explicit "supersedes / extends" field validated by the skill logic	P1
De-duplication	Instructs not to duplicate specs/ADRs/issues only	Diff new content against prior handoffs in same lineage before writing	P0
Length / token budget	None specified	Target size band + rule to summarize-by-reference instead of restating	P0
Diagrams / attachments	Not supported by the skill itself	Convention for linking generated diagrams/images alongside the .md file	P2
Evidence confidence tagging	Findings and assumptions listed together in prose	Tag each item verified / assumed / unconfirmed	P2
Self-validation step	None	Pre-save checklist: redaction done, all sections present, size within budget	P1
Output location semantics	"OS temp directory" — undefined in hosted/sandboxed clients	Environment-aware fallback path convention	P3

Table 5 — Prioritized backlog of skill enhancements (P0 = next iteration, P3 = future).

13. Recommendations

13.1 Immediate (P0)

- Add a lightweight de-duplication step: before writing, check whether a prior handoff in the same lineage exists and summarize-by-reference instead of restating shared findings.
- Introduce an explicit length/size target for the findings section, with a rule to move resolved items out rather than let lists grow unbounded.

13.2 Short-term (P1)

- Add YAML/JSON front-matter (id, parent_handoff, date, domain tags, version) so handoffs become machine-indexable, not just human-readable.
- Add a "supersedes / extends" field so lineage is explicit rather than inferred from prose.
- Add a pre-save self-validation checklist (redaction confirmed, all required sections present, size within budget) as a final skill step.

13.3 Medium-term (P2)

- Support linking generated diagrams/attachments alongside the Markdown file, with a defined naming convention.

- Tag each finding/assumption with a confidence level (verified / assumed / unconfirmed) to make risk triage faster for the receiving specialist.

13.4 Long-term (P3)

- Define environment-aware output-path behavior so "temporary directory of the user's OS" resolves sensibly whether the skill runs in a local CLI agent or a hosted chat sandbox.

14. Conclusion

The handoff skill performed reliably on the dimensions that matter most for correctness and safety: completeness, factual accuracy, redaction, and actionable prioritization were consistently strong across both tests. The clearest, most tractable improvement is lifecycle-awareness across successive handoffs — de-duplication, lineage metadata, and a length budget — which would prevent the measured 37% conceptual overlap from compounding as an investigation grows past two cycles. None of the identified gaps are structural blockers; all are additive enhancements to an already-functional skill definition.

Appendix A — Skill Definition Referenced

Evaluated skill: handoff (/mnt/skills/user/handoff/SKILL.md). Core instruction: compact the current conversation into a handoff document; save to the OS temp directory; include a suggested-skills section; avoid duplicating content in other artifacts (specs, plans, ADRs, issues, commits, diffs); redact sensitive information; tailor to any arguments passed.

Appendix B — Source Artifacts

- legacy-ems-security-assessment-handoff.md (Test 1 output)
- legacy-ems-architecture-security-handoff.md (Test 2 output)
- Token/overlap metrics computed via wc (GNU coreutils) and Python 3 (difflib, re) on both source files.